Below is a **detailed master table of DevSecOps terminology** used across **all modern DevSecOps versions/evolution (CI/CD → Cloud Native → GitOps → Zero Trust → AI/Policy-as-Code)** with **real-time use cases + software examples**.

✅ DevSecOps Terminology (Detailed) + Real-Time Use Cases + Examples (Master Table)

Legend

- **Use case** = where/why we use it in real industry DevSecOps
- **Example** = actual tools/software patterns

---

1) DevSecOps Foundation Terminology

Term	Meaning (Detailed)	Real-Time Use Case	Example
DevSecOps	Dev + Sec + Ops with security integrated in lifecycle	Prevent vulnerabilities before production	Security checks in PR pipeline
Shift Left Security	Move security earlier (coding stage)	Fix cheaper, faster	SAST in GitHub PR
Shift Right Security	Security monitoring in runtime	Detect attacks post deployment	Runtime WAF alerts
Secure SDLC (SSDLC)	Secure software lifecycle model	Standardized secure development	OWASP practices included
CI (Continuous Integration)	Frequent code merges & automated builds	Fast development	Jenkins build per commit
CD (Continuous Delivery)	Deploy-ready always (manual prod release possible)	Stable releases	Deploy to staging automatically
Continuous Deployment	Auto production deployment	SaaS rapid release	Push to prod after tests
Pipeline	Automated workflow chain	Automate everything	GitLab pipeline YAML
Automation	Remove manual steps	Speed + consistency	Automated testing + security scans

Immutable Infrastructure	Infra is never modified, only replaced	Prevent config drift	Replace EC2 instances via Terraform
Idempotency	Repeatable operation gives same result	Safe automation	Terraform apply repeatedly
Standardization	Same patterns everywhere	Reduce errors	Standard Jenkinsfile template

---

2) Source Control + Collaboration Terminology (Git + PR)

Term	Meaning (Detailed)	Real-Time Use Case	Example
Repository (Repo)	Version controlled code storage	Central collaboration	GitHub repo
Branching Strategy	Rules for branching	Controlled release management	GitFlow
Pull Request (PR)	Change proposal for review	Quality + security control	PR with approvals
Merge Request (MR)	Same as PR (GitLab)	Code review	GitLab MR
Code Review	Peer review of code	Prevent risky code	Approving PR
Protected Branch	Branch needs approvals & policies	Prevent direct prod push	main branch protected
Commit Signing	Verified commits (GPG)	Prevent forged commits	Signed commits in GitHub
Secrets in Repo	Leakage risk	Must be prevented	API key accidentally committed
.gitignore	Exclude files from repo	Avoid secrets/logs push	ignore *.env

---

3) CI/CD Pipeline Core Terminology

Term	Meaning	Use Case	Example
Build	Compile/package code	Create deployable artifact	Maven package / Gradle build

Artifact	Build output used for deployment	Reliable deploy	JAR, Docker image
Artifact Repository	Artifact storage	Controlled release	Nexus, Artifactory
Pipeline Stages	Steps in pipeline (build/test/scan/deploy)	Structure automation	GitHub Actions jobs
Quality Gate	Condition needed to proceed	Enforce standards	SonarQube gate
Promotion	Move build artifact to next env	Controlled release	Promote staging image to prod
Rollback	Restore previous version	Reduce downtime	Deploy previous Docker tag
Blue-Green Deployment	Two environments (blue & green)	Zero downtime	Switch traffic instantly
Canary Release	Gradual rollout to small %	Minimize risk	5% traffic to new version
Feature Flag	Enable/disable features at runtime	Safe feature delivery	LaunchDarkly
Deployment Strategy	Plan for deploying releases	Reliability	Rolling update

---

4) Security Scanning Terminology (DevSecOps Scanners)

Term	**Meaning (Detailed)**	**Real-Time Use Case**	**Example**
SAST	Static code security scan	Find bugs during coding	SonarQube, Checkmarx
DAST	Scan running app	Find runtime vulnerabilities	OWASP ZAP
IAST	Instrumented app security testing	Runtime + code context	Contrast Security
SCA	Dependency scan	Detect vulnerable libraries	Snyk, OWASP Dependency-Check
Secret Scanning	Detect secrets in code	Prevent leaks	GitHub secret scanning

Container Scanning	Scan images	Prevent vulnerable image deploy	Trivy, Clair
IaC Scanning	Scan Terraform/K8s YAML	Fix infra vulnerabilities early	Checkov
SBOM	List of all components used	Compliance + supply chain	CycloneDX, SPDX
Vulnerability Database	CVE feeds	Risk visibility	NVD, OSV
CVE	Known vulnerability ID	Patch mgmt	CVE-2021-44228
CVSS	Severity scoring system	Prioritize fixes	CVSS 9.8 critical
Threat Modeling	Identify risks before coding	Security design	STRIDE model
Penetration Testing	Manual hacking attempt	Confirm exploitability	Pentest reports

---

5) Compliance + Governance Terminology

Term	Meaning	Use Case	Example
Policy-as-Code	Automated security policies	Enforce compliance automatically	OPA Gatekeeper
Compliance-as-Code	Automated compliance checks	Audit-ready pipelines	CIS benchmarks checks
Audit Trail	Logs of actions	Regulatory requirement	Pipeline logs
Traceability	Track changes from issue to deployment	Governance	Jira + Git linking
Separation of Duties (SoD)	Dev != approver	Prevent insider risk	PR approval required
Access Control	Who can do what	Reduce privilege	RBAC
Risk Acceptance	Accept vulnerability temporarily	Business decision	Approve CVE risk

SLA / SLO / SLI	Reliability metrics	Service quality	SLO 99.9% uptime
GDPR	Privacy compliance	Protect user data	Data masking, consent logs
PCI DSS	Payment security compliance	Payment apps	Tokenization + audits
SOC2	Security controls framework	SaaS compliance	SOC2 readiness program

---

6) Infrastructure & Cloud Terminology

Term	Meaning	Use Case	Example
IaC	Infra written as code	Version control infra	Terraform modules
Terraform	IaC tool	Provision infra	VPC + EC2
CloudFormation	AWS IaC	AWS provisioning	CF templates
Configuration Management	Manage server configs	Standardized servers	Ansible, Chef
Cloud Native	Built for cloud	Scalability	Microservices on Kubernetes
Autoscaling	Auto add/remove resources	Handle traffic spikes	HPA in Kubernetes
Load Balancer	Distribute traffic	High availability	AWS ALB
VPC	Private cloud network	Secure isolation	AWS VPC

---

7) Kubernetes + Container DevSecOps Terminology

Term	Meaning	Use Case	Example
Container	Lightweight app package	Consistent runtime	Docker container
Dockerfile	Script to build image	Standard builds	FROM openjdk:17
Kubernetes (K8s)	Container orchestration	Microservices management	EKS cluster

Pod	Smallest deploy unit	App runtime unit	Pod with 2 containers
Deployment	Desired state for pods	Rolling updates	replicas=3
Service	Pod networking abstraction	Stable access	ClusterIP service
Ingress	HTTP routing	External exposure	Nginx ingress
Namespace	Isolation boundary	Multi-tenant	dev, staging, prod
RBAC	Permissions model	Access control	RoleBinding
Network Policy	Pod traffic rules	Zero trust network	deny-all by default
Admission Controller	Validate resources	Enforce policy	OPA Gatekeeper
Service Mesh	Traffic security + observability	mTLS inside cluster	Istio

---

8) Identity, Access, and Zero Trust Terminology

Term	**Meaning**	**Use Case**	**Example**
IAM	Identity and Access Management	Cloud permissions	AWS IAM roles
Zero Trust	Never trust, always verify	Internal security	Microsegmentation
Least Privilege	Minimal access needed	Reduce blast radius	Read-only role
MFA	Multi-factor auth	Prevent account takeover	OTP + password
SSO	Single sign-on	Central access mgmt	Okta login
JWT	Auth token	Microservice auth	Bearer token
OAuth2	Authorization framework	Delegated access	Login with Google
OIDC	Identity layer on OAuth2	Modern SSO	Keycloak OIDC

---

9) Observability + Monitoring + Incident Terminology

Term	Meaning	Use Case	Example
Observability	Understand system via signals	Debug + security	logs/metrics/traces
Logging	Store system logs	Troubleshooting	ELK stack
Metrics	Numeric indicators	Performance monitoring	Prometheus metrics
Tracing	Track request flow	Microservices debugging	Jaeger
Alerting	Notification of issues	Incident response	PagerDuty
SIEM	Security log analytics	Detect attacks	Splunk SIEM
SOAR	Automate security response	Auto-block attacks	Palo Alto Cortex
Incident Response (IR)	Handle security incidents	Damage control	IR playbook
Postmortem	Root cause analysis	Prevent recurrence	RCA report

---

10) GitOps + Modern DevSecOps Evolution Terms

Term	Meaning	Use Case	Example
GitOps	Git is source of truth for infra	Safer deployments	ArgoCD sync
Desired State	Expected infra config	Drift prevention	K8s YAML in Git
Drift	Actual infra differs from code	Risk detection	Manual changes in prod
Reconciliation	Tool corrects drift	Automated enforcement	ArgoCD self-heal
Declarative Config	Define “what”, not “how”	Consistency	K8s manifests
Progressive Delivery	Smart rollout automation	Safer releases	Flagger

---

✅ **Summary (How these terms help in real software)**

- **Banking/Finance apps** → compliance, audit trail, IAM, SAST/SCA, policy-as-code
- **E-commerce apps** → CI/CD + canary + monitoring + container scanning
- **Healthcare apps** → privacy + compliance + secure SDLC
- **SaaS products** → GitOps + continuous deployment + zero trust + observability

---

If you want, I can also generate:
✅ **DevSecOps terminology chart/architecture diagram (PNG)**
✅ **Tool mapping table** (Term → Top tools: Jenkins/GitLab/ArgoCD/Snyk/Trivy/SonarQube/OPA etc.)
✅ A complete **DevSecOps pipeline YAML example** (GitHub Actions / GitLab CI / Jenkinsfile) with security gates.

Below is the **DevSecOps Tool Mapping Table**: **Term → Top Tools → Real-time use case → Example** (covering Jenkins/GitLab/ArgoCD/Snyk/Trivy/SonarQube/OPA + more).

✅ **DevSecOps Tool Mapping Table (Term → Top Tools → Use Case → Example)**

Term / Area	What it means	Top Tools (Popular)	Real-Time Use Case	Example
Source Control (SCM)	Store and manage code	GitHub, GitLab, Bitbucket	Central repo for code	main branch with PR/MR
PR/MR Review	Peer review before merge	GitHub PR, GitLab MR	Prevent risky code merge	Require 2 approvals
Branch Protection	Prevent direct pushes	GitHub rules, GitLab Protected branches	Enforce governance	No push to main
CI Pipeline	Automated build/test	Jenkins, GitLab CI/CD, GitHub Actions, Azure DevOps	Automate build + test	mvn test on commit
CD Pipeline	Deploy artifacts	Jenkins, GitLab, Spinnaker, ArgoCD	Controlled deployments	Deploy to staging
GitOps	Git as source of truth	ArgoCD, FluxCD	Auto-sync deployments	Argo sync K8s YAML

Build Tool	Compile/package app	Maven, Gradle, npm/yarn, pip/poetry	Produce build output	mvn package creates JAR
Artifact Repository	Store build packages	Nexus, JFrog Artifactory, GitHub Packages	Reusable deploy artifact	Store myapp-1.0.jar
Containerization	Package app in container	Docker, Podman, Buildah	Consistent runtime	Build Docker image
Container Registry	Store container images	Docker Hub, ECR, GCR, ACR, Harbor	Deploy from central registry	myapp:1.2 in ECR
Kubernetes Orchestration	Manage containers at scale	Kubernetes, OpenShift	Run microservices	K8s deployments
Helm Packaging	K8s app packaging	Helm	Versioned deployments	helm upgrade –install
Kustomize	YAML customization	Kustomize	Env-specific overlays	prod overlay configs
Infra as Code (IaC)	Infra provisioning as code	Terraform, CloudFormation, Pulumi	Repeatable infra	VPC+EKS via Terraform
IaC Security Scan	Scan Terraform/K8s YAML	Checkov, tfsec, Terrascan, Snyk IaC	Prevent misconfigurations	Public S3 detection
Config Management	Manage server config	Ansible, Chef, Puppet, SaltStack	Standardized servers	Install Nginx via Ansible
Secrets Management	Secure secrets storage	HashiCorp Vault, AWS Secrets Manager, Azure Key Vault, GCP Secret Manager	Protect credentials	DB password stored in Vault
Secrets Scanning	Detect secrets in repo	Gitleaks, TruffleHog, GitHub Secret scanning	Stop leakage	Block leaked API key

SAST	Static Application Security Testing	SonarQube, Checkmarx, Fortify, Semgrep	Detect code vulnerabilities early	SQL injection finding
Code Quality	Maintain standards	SonarQube, PMD, SpotBugs, ESLint	Improve maintainability	Code smells detection
SCA	Dependency scanning	Snyk, OWASP Dependency-Check, Mend(WhiteSource), Black Duck	Detect vulnerable libs	Log4j CVE detection
SBOM	List of components used	Syft, CycloneDX, SPDX tools	Supply chain visibility	Generate SBOM JSON
DAST	Dynamic security scan	OWASP ZAP, Burp Suite, Acunetix	Scan running app	Test XSS runtime
IAST	Interactive runtime security	Contrast Security, Veracode IAST	Runtime + code context	Detect vuln during test
RASP	Runtime app protection	Contrast Protect, Imperva RASP	Block runtime attacks	Block injection attempts
Container Scanning	Scan docker images	Trivy, Clair, Anchore, Snyk Container	Vulnerable OS packages	Detect openssl CVE
Kubernetes Security Scan	Cluster YAML scanning	kube-score, kube-bench, kubescape	Enforce best practices	CIS K8s benchmark
Policy-as-Code	Enforce policies automatically	OPA, Gatekeeper, Kyverno	Enforce rules on deployment	Block privileged pods
Admission Controller	Validate K8s resources	OPA Gatekeeper, Kyverno	Stop insecure deploy	deny hostNetwork=true

Runtime Security	Detect runtime threats	Falco, Sysdig Secure, Aqua, Prisma Cloud	Detect container escape	Alert on suspicious syscall
WAF	Web app firewall	Cloudflare WAF, AWS WAF, F5, ModSecurity	Block web attacks	Block OWASP top 10
API Security	Protect APIs	Kong, Apigee, AWS API Gateway, Salt Security	Prevent API abuse	Rate limit + auth
IAM	Identity permissions	AWS IAM, Azure AD, Okta, Keycloak	Access control	Least privilege policy
RBAC (K8s)	Role-based access control	Kubernetes RBAC, OpenShift RBAC	Prevent unauthorized access	Read-only role for dev
MFA/SSO	Strong user authentication	Okta, Azure AD, Google Workspace	Reduce account takeover	MFA login required
Zero Trust	Never trust, always verify	BeyondCorp patterns, Zscaler, Cloudflare Zero Trust	Secure internal access	Microsegmentation
Service Mesh	Secure service-to-service	Istio, Linkerd, Consul	mTLS + observability	Enforce mTLS between services
Encryption	Secure data at rest/in transit	TLS, AWS KMS, Vault Transit	Prevent leakage	TLS for API traffic
Logging	Store logs	ELK, EFK, Splunk, CloudWatch	Debug + security audit	Central app logs
Metrics	Monitor performance	Prometheus, Grafana	Performance monitoring	CPU/RAM metrics
Tracing	Track request flow	Jaeger, Zipkin, OpenTelemetry	Debug latency	Trace across services

Observability	Logs+metrics+traces	OpenTelemetry, Grafana stack	Full visibility	APM dashboards
SIEM	Security event aggregation	Splunk, IBM QRadar, Sentinel	Detect attacks	Correlate login anomalies
SOAR	Security automation	Cortex XSOAR, Splunk SOAR	Automated response	Auto-block malicious IP
Alerting	Notifications	Alertmanager, PagerDuty, Opsgenie	Incident response	Pager triggered on downtime
Incident Management	Handle incidents	PagerDuty, Jira Service Mgmt, ServiceNow	On-call process	IR ticket creation
Ticketing	Task tracking	Jira, ServiceNow	Traceability	Link CVE to fix ticket
Compliance Reporting	Compliance automation	Chef InSpec, OpenSCAP, Prisma Cloud	Audit readiness	CIS compliance reports

---

✅ Quick Mapping (Your Requested Tools)

Tool	Best Used For
Jenkins	CI orchestration, build/test/deploy pipelines
GitLab CI/CD	Full SCM + CI/CD + DevSecOps pipelines
ArgoCD	GitOps continuous delivery for Kubernetes
Snyk	SCA + container scanning + IaC scanning
Trivy	Container scanning + K8s scanning (fast + popular)
SonarQube	SAST + code quality gates
OPA / Gatekeeper	Policy-as-code + Kubernetes admission control
Kyverno	Kubernetes native policy enforcement (easy rules)

If you want, I can also provide:
✅ a **DevSecOps pipeline example** (GitLab CI YAML or Jenkinsfile) including **SAST + SCA + Trivy + OPA Gatekeeper + ArgoCD deployment** end-to-end.